



UNIVERSIDAD DE COSTA RICA

Escuela de Matemáticas

Estadística Actuarial I (CA0303)

Bitácora #4

Prof: Maikol Solís

Estudiantes:

Anthony Flores Rojas (C32975)

Andrey González Bastos (C33329)

Randal Picado Bermúdez (C36024)

Leonardo Vega Aragón (C38313)

Fecha: 22/06/2026

Contenido

1. Parte de planificación	1
1.1. Fichas de resultados	1
2. Parte de escritura	2
2.1. Escribir, escribir, escribir	2
2.2. Conclusión	6
2.3. Introducción	7
2.4. Resumen	8
2.5. Ordenamiento final	8
3. Revisiones finales	9
4. Registro de uso de IA	10

Capítulo 1

Parte de planificación

1.1. Fichas de resultados

Holi.

Capítulo 2

Parte de escritura

2.1. Escribir, escribir, escribir

El presente proyecto fue desarrollado con el fin de analizar si las contraseñas de la base de datos *rockyou.txt* seguía la ley de Benford para los primeros 16 dígitos mediante alguna transformación de los datos. Sin embargo, para continuar con el proyecto, fue necesario abarcar varias definiciones, que serán presentadas a continuación.

1. **Ley de Benford:** Según Sarkar (2025), la Ley de Benford establece que los primeros números que se encuentran en una base de datos dada varían su cantidad de apariciones según los dígitos que los conforman. En síntesis, el número uno suele aparecer más frecuentemente, seguido por el dos, luego por el tres y así sucesivamente. Sin embargo, Marrero (2019) expone la limitación de que esta ley solo es válida cuando la muestra de números es variada, abarca diversos órdenes de magnitud, se encuentra libre de condicionamientos y sesgos, y tiene la característica de no ser totalmente aleatoria. Es por esto último que el primer autor mencionó el hecho de que dicha ley permite identificar patrones y anomalías en bases de datos “naturales”, lo que se puede aplicar al momento de detectar algunos tipos de fraude.
2. **Entropía:** Dada una variable aleatoria continua X con una función de densidad p , se define la Entropía de X como:

$$h(X) = \int_{-\infty}^{\infty} p(x) \log(p(x)) dx$$

Análogamente, para una variable aleatoria discreta X con función de masa p , su entropía corresponde a:

$$H(X) = \sum_{i=1}^n p(x_i) \log(p(x_i))$$

Conceptualmente, la entropía mide el nivel de aleatoriedad, desorden o variabilidad en un sistema cerrado. Así, cuanto más grande sea la magnitud asociada a la entropía de una variable aleatoria, habrá más incertidumbre al momento de hacer una predicción con respecto al comportamiento de dicha variable. (Reaz y Wunder, 2024). Los autores

Lehoucq, Mayer y Tucker hacen la distinción de que la entropía se utiliza de manera diferente en el contexto de teoría de la información (donde se utilizan variables aleatorias) que en el contexto de la estadística (donde se trabaja con muestras). Así, para este proyecto se hará uso de la entropía en los dos contextos mencionados anteriormente.

Posteriormente, para el aspecto metodológico del proyecto, se hizo uso de varias herramientas (las cuales serán explicadas con detalle en los siguientes párrafos), como lo fueron:

- Tokenización
- Test de Kolmogorov-Smirnov
- Prueba de Kruskal-Wallis

Al principio de la elaboración del proyecto, se quiso investigar acerca de los patrones que siguen las contraseñas a nivel general. Uno de los primeros trabajos que llamaron la atención del grupo fue el trabajo *User password repetitive patterns analysis and visualization*, el cual estudiaba acerca de si los usuarios reutilizan sistemáticamente subcadenas al crear contraseñas largas y cómo estos patrones de repetición debilitan las políticas actuales de seguridad basadas en longitud y complejidad. Se formalizaron varios tipos de patrones repetitivos dentro de una misma contraseña (caracteres individuales, pares y subcadenas de tres a diez caracteres, en orden unidireccional y bidireccional) y se diseñaron algoritmos en tiempo polinómico para detectarlos eficientemente sobre grandes conjuntos de datos filtrados de fugas reales como RockYou. Además, se implementó una herramienta web ligera, basada en D3, con cuatro vistas de visualización: gráficos de frecuencia de caracteres (CFC), mapas de calor de repeticiones cortas (SRH), coordenadas paralelas para repeticiones largas (LRPC) y nubes de palabras de subcadenas repetidas (RWC), que permiten a administradores explorar interactivamente repeticiones y filtrar por longitud, tipo de carácter y dirección. Los estudios de caso muestran que las contraseñas de los usuarios exhiben fuertemente repeticiones de caracteres del mismo tipo (dígitos, minúsculas o mayúsculas), que muchas contraseñas largas se construyen repitiendo subcadenas cortas significativas (p. ej. “love”, “haha”, “1212”) o patrones bidireccionales, y que estas estrategias de memorización hacen que exigir contraseñas más largas no garantice mayor seguridad, proporcionando solo una ilusión de robustez.

Luego, se analizó el trabajo *About Passwords*, que complementaba en gran medida lo visto en el párrafo anterior, pues analizaba críticamente varias creencias comunes sobre la seguridad de las contraseñas y sostiene, con argumentos combinatorios y evidencia empírica, que la longitud es un factor mucho más importante que la mera mezcla de mayúsculas, minúsculas, dígitos y símbolos. A partir de filtraciones reales como Hotmail, RockYou, Yahoo! y otros casos masivos, el autor mostró que muchos usuarios siguen eligiendo contraseñas triviales, reutilizadas o basadas en palabras comunes, información personal y patrones previsibles, lo que vuelve muy eficaces los ataques por diccionario, las variantes avanzadas con sustituciones tipo *leet* y los ataques de fuerza bruta fuera de línea. Seguidamente, se discutieron distintos métodos populares de generación de contraseñas, como combinaciones aparentemente aleatorias de caracteres, iniciales de frases, generadores deterministas por sitio y concatenaciones mnemotécnicas de palabras, subrayando que cualquier método conocido o estructuralmente típico puede facilitar el trabajo del atacante si este dispone de información previa o de listas

de patrones frecuentes. Luego se presentó un análisis estructural de más de 14 millones de contraseñas únicas de RockYou, donde se observa que predominan las minúsculas, los dígitos y las formas “palabra + números”, mientras que el uso de mayúsculas y caracteres especiales es relativamente escaso; además, se estima que una estrategia de cracking bien diseñada podría romper una fracción considerable de esas contraseñas en muy poco tiempo. Finalmente, el texto propuso recomendaciones prácticas para construir contraseñas robustas y memorables, por ejemplo mediante frases largas, combinaciones personales no previsibles o palabras inventadas, y concluye que la seguridad real depende tanto de buenos hábitos del usuario como de funciones hash fuertes, políticas organizacionales adecuadas y educación temprana sobre autenticación y riesgos informáticos.

Este texto sugiere fuertemente que el largo de una contraseña influye de manera directamente proporcional en su seguridad, y uno de sus argumentos es que entre más caracteres tiene una contraseña entonces habrían más combinaciones que deberían ser probadas al momento de querer vulnerarla (lo que haría poco probable que un intruso obtenga la respuesta en poco tiempo). Sin embargo, esta posición es contraria a la que ofrecen los autores de *User password repetitive patterns analysis and visualization*, pues estos últimos dejaron claro que aumentar la longitud de una contraseña no necesariamente implica un aumento en la seguridad, pues los humanos tienden a repetir patrones al momento de hacer una secuencia extensa de caracteres.

Para complementar el análisis que el texto anterior hizo del cambio que experimenta la seguridad de una contraseña al cambiar su longitud, se analizó el texto *The science of guessing: analyzing an anonymized corpus of 70 million passwords*, donde el autor presenta un análisis estadístico riguroso del mayor corpus anonimizado de contraseñas estudiado hasta ese momento, correspondiente a casi 70 millones de usuarios de Yahoo!, y lo utiliza para replantear la forma en que se mide la dificultad de adivinación de contraseñas elegidas por humanos. Se inicia criticando métricas tradicionales como la entropía de Shannon y la *guessing entropy*, por no ser apropiadas ni estimables con muestras realistas, y en su lugar introduce métricas de adivinación parcial como λ_β , μ_α y especialmente la nueva α -*guesswork*, pensadas para modelar ataques prácticos con distinta tasa deseada de éxito. Seguidamente, el trabajo propone un mecanismo de recolección que preserva la privacidad, basado en histogramas de contraseñas cifradas con un nonce secreto destruido antes del análisis, lo que permite estudiar subpoblaciones demográficas y de uso sin exponer contraseñas individuales ni facilitar ataques fuera de línea. Luego se aborda el problema del tamaño muestral, mostrando que incluso con decenas de millones de observaciones muchas métricas siguen subestimándose por la gran masa de contraseñas raras, y se adapta un modelo paramétrico de tipo Sichel (mezcla Poisson-generalized inverse Gaussian) para extrapolar la cola de la distribución y estimar con mayor estabilidad curvas de adivinación y factores de trabajo efectivos. Finalmente, al comparar numerosos subgrupos por edad, género, idioma, historial de cambios, uso de servicios y otros atributos, se concluye que la seguridad de las contraseñas varía sorprendentemente poco entre poblaciones: en general ofrecen menos de 10 bits de seguridad frente a ataques *online* y alrededor de 20 bits frente a ataques óptimos *offline*, lo que sugiere que incluso usuarios aparentemente más motivados siguen eligiendo contraseñas débilmente distribuidas y que los diccionarios globales funcionan casi tan bien como los específicos para cada grupo.

Una vez que se estudió la psicología que suelen aplicar las personas al momento de formar una contraseña, era momento de estudiar si realmente existe alguna manera de predecir

las contraseñas. Esto debido a que, de ser posible, significaría que las contraseñas realmente contiene patrones que se podría aprovechar para estudiar si, en el fondo, las contraseñas cumplen con la Ley de Benford. Uno de los primeros textos que se analizaron para estudiar esto fue *A study of Probabilistic Password Models* el cual realiza un estudio empírico amplio de modelos probabilísticos para contraseñas utilizando seis bases de datos reales con cerca de 60 millones de contraseñas, y propuso como alternativa metodológica a las curvas clásicas de número de intentos los *probability-threshold graphs*, que relacionan umbrales de probabilidad con el porcentaje de contraseñas cubiertas y permiten evaluar conjuntos completos con mucho menor costo computacional. Inició definiendo formalmente un modelo probabilístico de contraseñas como una función $p(s)$ sobre el conjunto de cadenas permitidas, y seguidamente se introdujeron tres métricas de evaluación principales: las *guess-number graphs*, las nuevas curvas de umbral de probabilidad y el *Average Negative Log-Likelihood* (ANLL), interpretado como el área a la izquierda de la curva de probabilidad y estrechamente relacionado con la perplejidad empírica. Luego se estudió un amplio espacio de diseño de modelos, distinguiendo entre modelos de Markov de cadena completa (*whole-string*) y modelos basados en plantillas (*template-based*), junto con decisiones de normalización, orden del modelo, suavizado, tratamiento de escasez de datos, agrupamiento de símbolos y esquemas de *backoff*, además de algoritmos de generación eficiente de conjeturas ordenadas por probabilidad. Finalmente, los resultados experimentales mostraron que los modelos de Markov de cadena completa bien contruidos, especialmente cuando combinan normalización con símbolo final y *backoff*, superan de forma consistente al modelo PCFGW, en particular más allá del primer millón de intentos, lo que lleva a concluir que estos enfoques ofrecen una representación más eficaz del comportamiento real de elección de contraseñas y una base más sólida para comparar fortaleza y capacidad de cracking.

El texto anterior se relacionaba en gran medida con el texto *A Machine Learning Approach to Predicting Passwords*, el cual exploraba el uso de modelos de aprendizaje automático para predecir secuencias de contraseñas humanas a partir de filtraciones públicas y compararlos con técnicas estándar de cracking basadas en hashcat. Tras repasar ataques de diccionario, diccionario+reglas, diccionarios masivos y fuerza bruta sobre contraseñas MD5 de XSplit, se mostró que los diccionarios ordenados por frecuencia (rockyou.txt) son muy eficientes en las primeras conjeturas, que combinar reglas casi duplica la tasa de éxito a costa de muchos más intentos, que listas enormes cubren casi todos los hashes y que la fuerza bruta es exhaustiva pero extremadamente ineficiente. El trabajo propuso luego una red neuronal con capas convolucionales 1D y densas, entrenada en 150 000 contraseñas de OwnedCore, para estimar la probabilidad del siguiente carácter dada la secuencia previa, logrando una exactitud de validación de alrededor de 41 % en predicción de carácter y permitiendo asignar a cada contraseña una probabilidad interpretable como medida de fortaleza (contraseñas comunes como “oblivion” o “asdf1234” reciben alta probabilidad; cadenas aleatorias como “xy2zx9nm”, probabilidades ínfimas). Mediante muestreo sobre la distribución de salida, la red genera listas de contraseñas plausibles que, usadas como diccionario en hashcat, logran romper alrededor de 1 % de 100 000 hashes con menos de un millón de conjeturas, cifra razonable dado que el diccionario contiene menos de un millón de contraseñas únicas, aunque claramente por debajo del rendimiento de rockyou.txt; aplicar reglas sobre estas contraseñas generadas mejora los resultados pero sigue sin alcanzar a los diccionarios artesanales. El autor concluyó que las redes neuronales son útiles para modelar el comportamiento de elección de contraseñas,

generar diccionarios especializados y ordenar listas por probabilidad (especialmente relevante con hashes costosos como bcrypt), pero que, en su implementación actual, la generación es lenta, el modelo aún está por detrás de las listas tradicionales en cracking y sería necesario investigar arquitecturas avanzadas (GAN, LSTM) y mejores representaciones para hacerlo competitivo.

Por un lado, el autor de *A study of Probabilistic Password Models* realizó su investigación de la fortaleza de las contraseñas mediante conceptos del área de probabilidad. Por el otro lado, el autor del artículo *A Machine Learning Approach to Predicting Passwords* utiliza un modelo con redes neuronales para estudiar la misma cualidad, sin hacer uso (aparentemente) de conceptos probabilísticos complejos.

Siguiendo en esta línea de modelos relacionados al estudio de la predictibilidad de las contraseñas, se estudió el trabajo *Zipf's Law in Passwords*, donde el autor analiza empíricamente la distribución de contraseñas de usuarios a gran escala y muestra que se ajusta notablemente bien a modelos tipo ley de Zipf. A partir de 14 conjuntos de datos reales con 113,3 millones de contraseñas, los autores proponen dos modelos Zipf-like: PDF-Zipf, que describe la frecuencia de las contraseñas populares y alcanza coeficientes de determinación superiores a 0,97, y CDF-Zipf, que ajusta prácticamente todo el rango de la distribución con desviaciones máximas entre la CDF empírica y la teórica de 0,49 % a 4,59 % (media\$ \$1,85 %). Sobre esta base, introducen una nueva métrica de fuerza de conjuntos de contraseñas derivada de los parámetros Zipf, y muestran mediante experimentos que dicha métrica es estable y aplicable a distintos sitios y políticas, permitiendo comparar con rigor qué tan “seguro” es el universo de contraseñas de un servicio independientemente del medidor ad hoc que se use en la interfaz. El trabajo discute además implicaciones para el diseño y evaluación de políticas de creación de contraseñas, subrayando que comprender la distribución subyacente (y su carácter Zipfiano) es clave para resolver las inconsistencias entre medidores de fuerza y para prever el impacto de reglas más estrictas sobre la seguridad y la usabilidad.

2.2. Conclusión

La presente investigación buscó responder en qué medida los patrones estructurales de las contraseñas de RockYou, su composición de caracteres, longitud y distribución de dígitos, determinan su entropía y evidencian que los usuarios no las eligen al azar. Esta pregunta sustituyó a la de la Bitácora #2, centrada solo en Benford, pues rockyou.txt carecía de metadatos de usuario. Acompañados del profesor Maikol Solís se reorientó el proyecto hacia un enfoque estructural y entrópico, sin abandonar Benford, sino aplicándolo sobre la suma de los vectores de tokenización cl100k de cada contraseña.

Se esperaba hallar sesgos sistemáticos detectables estadísticamente, y los resultados coincidieron solo en parte el test KS rechazó Benford en las posiciones 1 y 2 de esa suma tokenizada, pero no a partir de la posición 3, donde lo empírico y lo teórico convergen a la uniformidad; Kruskal-Wallis confirmó que máscara y longitud determinan la entropía de Shannon, y la matriz de bigramas mostró orden en la transición entre tipos de carácter. La metodología, combinando tokenización, pruebas no paramétricas y entropía, resolvió la pregunta desde varios ángulos, aunque no sin tropiezos: aplicar Benford directamente sobre los dígitos sin tokenizar fracasó por las fechas, las longitudes acotadas y los sesgos cognitivos

de los usuarios, lo que obligó a replantear el enfoque hacia la suma tokenizada. Para trabajos futuros se recomienda probar otras normas o esquemas de tokenización que extiendan el ajuste a Benford a todas las posiciones y complementar los hallazgos con modelos de Markov o redes generativas.

Finalmente, este trabajo llena un vacío poco explorado: ni los estudios de Benford (Caputi, 2019; Nigrini, 2012) ni los de seguridad de contraseñas (Bonneau, 2012; Wang et al., 2017) habían combinado la tokenización de los modelos de lenguaje con pruebas estadísticas formales para medir la predecibilidad de contraseñas, lo que vuelve esta investigación un puente metodológico novedoso entre ambas tradiciones.

2.3. Introducción

El desarrollo de la tecnología y las bases de datos electrónicas han llegado a cambiar el juego de la información. Cada día se les confían más datos personales y sensibles a distintos softwares, ya sea la aplicación bancaria que se usa para realizar una transacción, o tal vez la aplicación de salud que se utilice para medir el estado de la misma, ambas usan datos sumamente sensibles y privados acerca de las personas, su estilo de vida, sus gustos, etc.

Con este desarrollo inminente, las contraseñas han redefinido su importancia en el diario vivir de las personas, antes, cuando se pensaba en una contraseña, se pensaba en una caja fuerte de algún banco que se abría si se digitaba correctamente una sucesión de números que solo los altos mandos conocían, sin embargo, hoy en día, las contraseñas en los entornos digitales representan la seguridad de miles de millones de datos sensibles de millones de usuarios alrededor del mundo, que en caso de filtrarse o saberse, causaría un caos a nivel global.

En la investigación, se usará el sonado caso de la filtración de RockYou, un hackeo que se realizó en el año 2009, del cual se obtuvo un dataset lo suficientemente robusto de contraseñas para poder realizar análisis y estudios posteriores. Sabiendo todo lo anterior, resulta fundamental y oportuno, estudiar a detalle la composición de las contraseñas y como los usuarios tienden a elegir estas mismas. Saber la naturaleza de las contraseñas resulta beneficioso para así poder detectar anomalías en bases de datos de contraseñas, así como posibles ataques a los sistemas informáticos de instituciones por ejemplo bancarias, que, de vulnerarse su información, puede causar un desastre económico a nivel nacional o global, dependiendo del alcance de la entidad. En específico, el tema de la presente investigación se trata de indagar sobre la aleatoriedad de las contraseñas, con la pregunta de investigación planteada por el grupo, ¿En qué medida los patrones estructurales de las contraseñas del dataset RockYou —su composición de caracteres, longitud y distribución de dígitos— determinan su nivel de entropía y evidencian que los usuarios no eligen contraseñas de forma aleatoria?, se pretende descubrir si los humanos toman en cuenta la aleatoriedad o solo se basan en patrones muy conocidos y fáciles de recordar, vulnerando así su seguridad. Es bien conocido que el ser humano tiende a seguir patrones y escapa constantemente de la incertidumbre, es por esto que se puede llegar a medir la aleatoriedad de las contraseñas mediante el concepto de entropía. La entropía, entendida como una medida de aleatoriedad e impredecibilidad, permite cuantificar qué tan difícil es para un atacante adivinar o descifrar una contraseña determinada. Una contraseña con alta entropía implica una mayor cantidad de combinaciones posibles, lo

que la hace significativamente más resistente ante ataques de fuerza bruta o de diccionario. Sin embargo, la pregunta que surge de forma natural es si los usuarios, al momento de crear sus contraseñas, realmente priorizan esta aleatoriedad, o si, por el contrario, siguen patrones predecibles dictados por la comodidad y la memoria.

Para robustecer el análisis y darle un mayor rigor estadístico, la investigación incorpora herramientas que van más allá de la estadística descriptiva convencional. Por un lado, se aplicará la Ley de Benford, un principio matemático que establece la distribución esperada del primer dígito significativo en conjuntos de datos numéricos de origen natural o no manipulado. Por otro lado, se recurrirá a pruebas de bondad de ajuste como la prueba de Kolmogorov-Smirnov y la prueba de Kruskal-Wallis, las cuales permitirán evaluar si la distribución de las contraseñas sigue o se aleja significativamente de lo que cabría esperar bajo un modelo de aleatoriedad pura.

La combinación de estos enfoques ofrece una perspectiva tanto descriptiva como inferencial, permitiendo no solo caracterizar los patrones presentes en el dataset, sino también validar estadísticamente la hipótesis de que los usuarios, lejos de actuar al azar, siguen tendencias estructurales profundamente arraigadas al momento de construir sus contraseñas. Adicionalmente, el análisis incorpora un enfoque proveniente del procesamiento de lenguaje natural mediante la tokenización cl100k, el esquema de codificación utilizado por modelos de lenguaje de gran escala como GPT-4. Este proceso consiste en descomponer las contraseñas en unidades mínimas de significado llamadas tokens, esto para poder simplificar el análisis de las contraseñas por la combinación de letras y caracteres.

2.4. Resumen

2.5. Ordenamiento final

Capítulo 3

Revisiones finales

Capítulo 4

Registro de uso de IA